

Phụ Lục: Báo Cáo Kiểm Toán AI Toàn Diện (Comprehensive AI Audit Report)

Sinh viên thực hiện: Lâm Hữu Khánh

Mã số sinh viên: 23127205

Môn học: Kiểm thử phần mềm (Software Testing) — HW06: Kiểm thử API & Ứng dụng AI

Học kỳ: HK3 (2025-2026) — Khoa CNTT, Trường ĐH KHTN, ĐHQG-HCM

Thời gian thực hiện: 30/08/2026 – 01/09/2026

Môi trường tương tác: Google Antigravity IDE (Claude 3.7 Sonnet / Gemini 2.0 Flash)

1. Khai Báo Sử Dụng AI (Mandatory AI Declaration)

"I declare that I used AI tools (Google Antigravity / Claude 3.7 Sonnet / Gemini 2.0 Flash) collaboratively for the following engineering tasks, under strict Human-in-the-Loop supervision and empirical verification:"

- Phân tích tài liệu yêu cầu SUT (`eshop-sut/api_specification.md`) và chuyển đổi sang đặc tả chuẩn OpenAPI 3.0 YAML (`docs/openapi.yaml`).
- Sinh bộ test cases API có cấu trúc cho 3 phân hệ cốt lõi:
 - **Pool A:** FR-02 — Đăng nhập & Khóa tài khoản (`POST /api/login`)
 - **Pool B:** FR-07 — Quản lý Giỏ hàng (`GET /api/cart` , `POST /api/cart`)
 - **Pool C:** FR-15 — Quản lý Sản phẩm CRUD (`POST/GET/PUT/DELETE /api/products`)
- Thiết kế kiến trúc 4 tầng và mã nguồn cho công cụ AI Test Generator (`agent-skill/scripts/generate_api_tests.py`).
- Xây dựng bộ test suite Postman Collection v2.1 (Sanity, Bug Discovery, Data-Driven, Mock Server).
- Cấu hình CI/CD Pipeline GitHub Actions và xây dựng các kịch bản kiểm thử tự động với Newman CLI.
- Viết script tự động hóa đồng bộ 12 Bug Reports lên GitHub Issues và render báo cáo PDF chuẩn vector.

2. Nhật Ký Toàn Bộ Các Phiên Tương Tác AI (Detailed AI Interaction & Audit Logs)

Dưới đây là biên bản kiểm toán chi tiết của toàn bộ 12 Phiên làm việc cộng tác (Collaborative Human-AI Sessions) diễn ra trong suốt quá trình hoàn thành bài tập HW06:

Phiên 1: Khởi Tạo Dự Án & Phân Bỏ Nhiệm Vụ Nhóm (Team Task Allocation)

- Thời gian:** 2026-08-30 19:30:00 +07:00
- Mục tiêu:** Phân tích đề bài HW06, xác định 3 phân hệ Pool A (FR-02), Pool B (FR-07), Pool C (FR-15) cho Thành viên 1 (`23127205`), và lập kế hoạch phân công công việc.
- Prompt của người dùng:**

text Hãy phân tích đề bài HW06, đối chiếu với phân bổ bài tập nhóm. Tôi là Thành viên 1 (Lâm Hữu Khánh - 23127205). Hãy tạo tài liệu phân công nhiệm vụ và cấu trúc thư mục dự án chuẩn theo quy định nộp bài.

- **Đầu ra ban đầu của AI:** Tạo cấu trúc thư mục ban đầu và tài liệu phân công công việc `docs/hw06-team-task-allocation.md`.
- **Kiểm toán & Hiệu chỉnh của con người (Human Audit):**
- AI ban đầu đặt các file báo cáo phân tán ở thư mục gốc `HW6/`. Người dùng yêu cầu gom toàn bộ dự án vào thư mục duy nhất `HW06/` và tách bạch rõ ràng: `reports/` chứa báo cáo, `docs/` chứa tài liệu tham khảo đặc tả.

Phiên 2: Chuyển Đổi Đặc Tả SUT sang Chuẩn OpenAPI 3.0

- **Thời gian:** 2026-08-30 20:00:00 +07:00
- **Mục tiêu:** Tạo file đặc tả hợp đồng API `docs/openapi.yaml` làm đầu vào chuẩn hóa cho Agent Skill.
- **Prompt của người dùng:**
`text Chuyển đổi toàn bộ đặc tả API từ eshop-sut/api_specification.md thành file OpenAPI 3.0 YAML hoàn chỉnh (docs/openapi.yaml) với đầy đủ schema models, parameters, request body và response codes.`
- **Đầu ra ban đầu của AI:** File `openapi.yaml` với 15 endpoints.
- **Kiểm toán & Hiệu chỉnh của con người (Human Audit):**
- **Lỗi của AI:** AI định nghĩa `price` là kiểu `number` dạng float tự do và thiếu mã lỗi `403 Forbidden` trên các route yêu cầu quyền Admin.
- **Hiệu chỉnh:** Chuẩn hóa `price` sang `integer (VND)` và bổ sung đầy đủ securitySchemes `BearerAuth` cho các route nhạy cảm.

Phiên 3: Sinh Bộ Test Cases Cho FR-02 — Đăng Nhập & Khóa Tài Khoản (`POST /api/login`)

- **Thời gian:** 2026-08-30 20:45:00 +07:00
- **Mục tiêu:** Thiết kế 38 Test Cases bao phủ Domain, State Transition, Security và Schema Validation.
- **Prompt của người dùng:**
`text Bạn là Senior API QA Automation Engineer. Thiết kế 38 Test Cases cho POST /api/login theo 4 kỹ thuật: Phân hoạch tương đương & Giá trị biên (14 TCs), Chuyển trạng thái khóa tài khoản (9 TCs), Bảo mật SEC-01..07 (9 TCs), Schema Validation (6 TCs).`
- **Đầu ra ban đầu của AI:** Bảng 38 Test Cases với kỳ vọng `400 Bad Request` cho email sai format.
- **Kiểm toán & Hiệu chỉnh của con người (Human Audit):**
- **Ảo giác của AI (`INVALID`):** AI giả định server trả về `400 Bad Request` khi gửi email không có `@`. Thực tế kiểm tra mã nguồn `server.js:L33-40`, server truy vấn SQLite và trả về `401 Unauthorized`.
- **Phát hiện Bug SUT quan trọng:** Kiểm toán mã nguồn phát hiện SUT tăng `login_attempts + 2` mỗi lần sai (`server.js:L54`) và khóa `180000ms` (3 phút thay vì 30 giây tại `server.js:L57`).
- **Lỗi hỏng bảo mật SEC-01:** AI không tự phát hiện response login trả về trường `password` plaintext (`server.js:L52`). Kỹ sư con người đã bổ sung test case bắt lỗi hỏng này.

Phiên 4: Sinh Bộ Test Cases Cho FR-07 — Quản Lý Giỏ Hàng (`GET /api/cart` , `POST /api/cart`)

- **Thời gian:** 2026-08-30 21:40:00 +07:00
- **Mục tiêu:** Thiết kế 38 Test Cases cho phân hệ Giỏ hàng EShop.
- **Prompt của người dùng:**
`text Thiết kế 38 Test Cases cho FR-07 (Giỏ hàng) bao gồm kiểm tra phân hoạch số lượng, cộng dồn sản phẩm, phân quyền xác thực Bearer Token và IDOR.`
- **Đầu ra ban đầu của AI:** Sinh 38 Test Cases, trong đó có 6 test cases gọi đến `PUT /api/cart` và `DELETE /api/cart/:id`.
- **Kiểm toán & Hiệu chỉnh của con người (Human Audit):**

- **Ảo giác nghiêm trọng của AI (INVALID):** AI tự suy diễn rằng SUT đã có sẵn route `PUT /api/cart` (cập nhật số lượng) và `DELETE /api/cart/:id` (xóa sản phẩm). Thực tế kiểm tra `server.js`, phân hệ giỏ hàng chỉ cài đặt duy nhất 2 route `GET` và `POST`. Toàn bộ request `PUT/DELETE` đều bị `404 Not Found`.
- **Hiệu chỉnh:** Chuyển 6 test case này sang `02_Bug_Discovery_Suite` để lập báo cáo thiếu tính năng cốt lõi (Missing Features). Đồng thời phát hiện SUT chấp nhận số lượng âm `quantity = -5` và `quantity = 0` (`BUG-FR07-01`, `BUG-FR07-02`).

Phiên 5: Sinh Bộ Test Cases Cho FR-15 — Quản Lý Sản Phẩm CRUD (`POST/GET/PUT/DELETE /api/products`)

- **Thời gian:** 2026-08-30 22:30:00 +07:00
- **Mục tiêu:** Thiết kế 38 Test Cases cho phân hệ Quản lý Sản phẩm Admin.
- **Prompt của người dùng:**
`text Thiết kế 38 Test Cases cho FR-15 Product CRUD (POST/GET/PUT/DELETE /api/products) bao phủ xác thực quyền Admin (SEC-03), BVA giá và tên sản phẩm.`
- **Đầu ra ban đầu của AI:** 38 Test Cases giả định rằng không có token Admin thì server trả về `401/403`.
- **Kiểm toán & Hiệu chỉnh của con người (Human Audit):**
- **Lỗi hồng bảo mật nghiêm trọng (SEC-03):** Khi đối chiếu mã nguồn `server.js:L167, 179, 191`, phát hiện backend hoàn toàn quên gắn middleware `authenticateToken`. Bất kỳ ai không cần đăng nhập cũng có thể thêm/sửa/xóa sản phẩm trong CSDL!
- **Lỗi ép kiểu String (BUG-FR15-02):** Tại `server.js:L162`, tác giả backend cố tình viết `if (row.id % 2 === 0) row.price = String(row.price);`. AI ban đầu bỏ qua chi tiết này. Con người đã bổ sung schema assertion kiểm tra `typeof jsonData.price === 'number'`.

Phiên 6: Xây Dựng Agent Skill — Bộ Sinh Test Tự Động (Bloom-AI G9.5 Create)

- **Thời gian:** 2026-08-31 09:00:00 +07:00
- **Mục tiêu:** Thiết kế kiến trúc 4 tầng, Pseudocode và mã nguồn Python thực thi cho AI API Test Generator.
- **Prompt của người dùng:**
`text Hãy xây dựng Agent Skill hoàn chỉnh cho HW06: Sơ đồ kiến trúc 4 tầng, file pseudocode và script Python generate_api_tests.py tự động đọc OpenAPI YAML sinh ra Postman Collection và tự động chạy Newman.`
- **Đầu ra ban đầu của AI:** Script Python cơ bản sinh test dạng template tĩnh.
- **Kiểm toán & Hiệu chỉnh của con người (Human Audit):**
- Nâng cấp script thành công cụ dòng lệnh đầy đủ hỗ trợ 4 chiến lược kiểm thử (`happy_path`, `boundary`, `security`, `schema`), tự động inject Pre-request Script gán `X-Student-Id: 23127205` và tích hợp runner Newman CLI.
- Tự vẽ sơ đồ kiến trúc `agent-skill/diagram.png` theo đúng quy định chống gian lận Mục 11.

Phiên 7: Xây Dựng Postman Collection & Data-Driven CSVs

- **Thời gian:** 2026-08-31 14:00:00 +07:00
- **Mục tiêu:** Đóng gói 132 test cases vào Postman Collection v2.1 với 4 thư mục chuyên biệt.
- **Prompt của người dùng:**
`text Hãy hoàn thiện file HW06_API_Testing.postman_collection.json chứa đủ: 01_Sanity_Suite (43 TCs), 02_Bug_Discovery_Suite (9 TCs), 03_Data_Driven_Suite (3 CSV runners), 04_Mock_Server_Demo (2 TCs).`
- **Kiểm toán & Hiệu chỉnh của con người (Human Audit):**

- Kiểm tra tính toàn vẹn của các biến môi trường `{{base_url}}`, `{{admin_token}}`, `{{user_token}}`.
 - Thiết lập Collection Pre-request Script tự động inject header `pm.request.headers.upsert({ key: 'X-Student-Id', value: studentId })`.
-

Phiên 8: Kiểm Toán Bằng Chứng Xác Thực Sinh Viên (`X-Student-Id`) & Newman Run

- Thời gian: 2026-09-01 15:30:00 +07:00
 - Mục tiêu: Chứng minh sinh viên thật thực thi kiểm thử thật (Anti-Fraud Constraints theo Mục 11).
 - Thắc mắc của người dùng: "cách chụp ảnh minh chứng postman hướng dẫn chi tiết", "ảnh newman đâu có student header", "chụp postman như nào gửi request như nào".
 - Hướng dẫn & Kiểm toán của AI:
 - Giải thích rõ cơ chế: Dynamic header được inject qua Pre-request Script không hiển thị trên bảng UI tính mà chỉ xuất hiện trong **Postman Console** (`Ctrl + Alt + C`) tại thời điểm gửi request thực tế.
 - Người dùng thực hiện gửi request `TC_FR02_02_Valid_Admin_Login` trên Postman, mở Postman Console chụp lại bằng chứng `x-student-id: "23127205"` -> Lưu thành công vào `reports/screenshots/console-student-id.png`.
 - Người dùng chạy lệnh `npx newman run ...` trên terminal -> Chụp lại màn hình terminal hiển thị 118 assertions passed -> Lưu vào `reports/screenshots/newman-local-run.png`.
-

Phiên 9: Tái Hiện & Bắt Trộn 12 Lỗi Thực Tế Trong Postman

- Thời gian: 2026-09-01 16:15:00 +07:00
 - Mục tiêu: Chụp ảnh minh chứng thực tế cho toàn bộ 12 Bug Reports từ Issue #1 đến Issue #12.
 - Thắc mắc của người dùng: "cái bug 2 thời gian hiển thị gì ở đâu??", "cái issue 10 response v nè sai nhe: price: '28000000'".
 - Hướng dẫn & Kiểm toán của AI:
 - Bug 2 (Lockout Duration 180s): Hướng dẫn người dùng nhập sai mật khẩu 2 lần liên tiếp để kích hoạt trạng thái khóa, server trả về `403 Forbidden` và trích dẫn dòng code `server.js:L57` thiết lập `Date.now() + 180000ms`.
 - Bug 10 (Ép kiểu price sang chuỗi): Xác nhận với người dùng rằng `"price": "28000000"` (có dấu ngoặc kép String) chính là lỗi nghiệp vụ do `server.js:L162` ép kiểu ở ID chặn.
 - Người dùng đã hoàn thành capture đủ 12 ảnh thực tế và lưu vào `reports/screenshots/github-issues/issue-1.png` ~ `issue-12.png`.
-

Phiên 10: Tự Động Hóa Đẩy 12 Bug Reports Lên GitHub Issues

- Thời gian: 2026-09-01 16:45:00 +07:00
 - Mục tiêu: Xuất bản 12 báo cáo lỗi lên GitHub Issues của repository `HCMUS-software-testing/HW06`.
 - Yêu cầu của người dùng: "tạo script để đẩy lên github issues, xóa icon trang trí, viết tiếng Việt có dấu đầy đủ và kèm ảnh bug".
 - Thực thi & Kiểm toán:
 - Xây dựng script `agent-skill/scripts/push_github_issues.py` gọi GitHub REST API v3.
 - Loại bỏ hoàn toàn emoji trang trí, chuẩn hóa tiêu đề và nội dung Tiếng Việt có dấu, cung cấp đầy đủ các bước tái hiện (Steps to Reproduce) và những link ảnh từ branch `khanh`.
 - Cập nhật thành công toàn bộ 12 Issues: [Issue #5 đến Issue #16](#).
-

Phiên 11: Chứng Minh 2 Lần Chạy CI/CD Mẫu Trên GitHub Actions (Pass & Fail)

- Thời gian: 2026-09-01 16:55:00 +07:00
- Mục tiêu: Thực hiện 2 pipeline runs thực tế (1 run Pass 100%, 1 run Fail bắt lỗi) theo Mục 14 Đề bài.
- Thực thi & Kiểm toán:
- Run Pass (Xanh): Commit `8765adc` trên branch `khanh` -> Run link: `https://github.com/HCMUS-software-testing/HW06/actions/runs/33494115345` (43 requests / 118 assertions passed).
- Run Fail (Đỏ): Cố tình thay đổi assertion mong đợi status code 999 tại commit `83ea05e` -> Run link: `https://github.com/HCMUS-software-testing/HW06/actions/runs/33494842155` (Pipeline báo đỏ và in log lỗi).
- Khôi phục (Revert): Revert assertion về 200 OK tại commit `0d1bae6` để giữ kho mã nguồn luôn trong trạng thái chuẩn mực.

Phiên 12: Khắc Phục Sự Cố Render PDF (PDF.js Type3 Patterns & Mermaid SVG)

- Thời gian: 2026-09-01 17:00:00 +07:00
- Mục tiêu: Xử lý triệt để lỗi PDF.js crash trên VS Code và hỗ trợ render biểu đồ Mermaid trong PDF.
- Phản hồi của người dùng: "hiện tại khi generate pdf thì cái chart mermaid bị lỗi".
- Phân tích nguyên nhân & Khắc phục:
- Nâng cấp `agent-skill/scripts/generate_pdf.py` tích hợp thư viện `mermaid.js` tự động chuyển đổi khối ````mermaid` thành thẻ `<div class="mermaid">` và render thành đồ họa Vector SVG sắc nét trước khi in PDF.
- Sử dụng TrueType font stack và thay thế emoji bằng text markers (`[+]` , `[Pass]` , `[Bug]`) để loại bỏ 100% Type3 bitmap font patterns.
- Kết xuất thành công toàn bộ 6 file PDF báo cáo chuẩn A4 tương thích mọi PDF viewer.

3. Bảng Tổng Hợp Số Liệu Kiểm Toán AI Toàn Dự Án

Hạng mục kiểm toán	Số lượng AI sinh	Số lượng Hợp lệ (<code>VALID</code>)	Số lượng Bị lỗi/Ảo giác (<code>INVALID</code>)	Số lượng Thiếu sót (<code>INCOMPLETE</code>)	Tỷ lệ Con người can thiệp
Test Cases FR-02 (Đăng nhập)	38	31 (81.6%)	5 (13.2%)	2 (5.3%)	18.4%
Test Cases FR-07 (Giỏ hàng)	38	30 (78.9%)	3 (7.9%)	5 (13.2%)	21.1%
Test Cases FR-15 (CRUD Sản phẩm)	38	31 (81.6%)	5 (13.2%)	2 (5.3%)	18.4%
OpenAPI 3.0 Endpoints	15	13 (86.7%)	0 (0.0%)	2 (13.3%)	13.3%
Phát hiện Lỗ hổng Bảo mật	4	1 (25.0%)	0 (0.0%)	3 (75.0%)	75.0%
CI/CD Workflow & Scripts	5	4 (80.0%)	1 (20.0%)	0 (0.0%)	20.0%
TỔNG CỘNG	138	110 (79.7%)	14 (10.1%)	14 (10.1%)	20.3%

4. Kết Luận Kiểm Toán & Nguyên Tắc Cộng Tác Human-in-the-Loop

- Hiệu suất vượt bậc:** AI giúp tăng tốc độ sinh boilerplate code, cấu trúc hóa dữ liệu OpenAPI và thiết lập ma trận kiểm thử ban đầu nhanh gấp 5-10 lần so với thao tác thủ công.
- Nguy cơ tiềm ẩn:** AI dễ mắc phải **ảo giác endpoint** (tự chế route không có thực) và **bỏ sót lỗ hổng bảo mật nghiêm trọng** do chỉ suy diễn bề mặt văn bản đặc tả mà không phân tích sâu mã nguồn backend.
- Vai trò không thể thay thế của Kỹ sư QA con người:** Con người đóng vai trò chốt chặn chất lượng (Quality & Security Gatekeeper), thực hiện kiểm toán mã nguồn (White-box audit), thiết lập môi trường CSDL cô lập và thẩm định an toàn thông tin trước khi đưa vào pipeline tự động.